

TUMBUH

Testing Plan Integrasi Keamanan

Rencana pengujian Authentication, Authorization, Accounting, enkripsi, dan digital signature

Kelompok 9	Ghiffari Bravia Hisham - G6401231050 Adam Naufal - G6401231082 Rafif Muhammad Farras - G6401231102
Sistem	TUMBUH - Career & Internship Tracker

1. Tujuan Pengujian

- Membuktikan authentication menolak kredensial salah dan menerbitkan token valid untuk akun aktif.
- Membuktikan authorization berbasis role dan ownership diterapkan di backend.
- Membuktikan accounting mencatat aktivitas penting tanpa membocorkan secret atau data sensitif.
- Membuktikan strategi perlindungan data sensitif dan digital signature siap diuji pada workflow utama.

2. Testing Environment

Komponen	Konfigurasi uji
Frontend	React/Vite lokal staging yang diarahkan ke backend testing.
Backend	FastAPI dengan database testing dan SECRET_KEY khusus testing.
Database	PostgreSQL lokal melalui Docker Compose atau Supabase dev/staging.
Audit log	audit-log service pada AUDIT_LOG_URL lokal/staging, misalnya http://localhost:3001/log .
Tools	Swagger UI, curl/Postman, pytest/httpx jika automated test disiapkan.

3. Minimum Data Testing

Data	Kebutuhan
Akun student	Akun aktif dengan profil mahasiswa, resume, bookmark, dan setidaknya satu lamaran.
Akun HR A	Akun aktif dengan company_id A dan minimal satu opportunity milik company A.
Akun HR B	Akun aktif dengan company_id B untuk negative ownership test.
Akun admin	Akun aktif role admin untuk endpoint /admin.
Opportunity	Minimal satu opportunity aktif dan satu opportunity berbeda company.
Application	Lamaran student pada opportunity company A untuk uji status update dan audit.

4. Matriks Skenario Authentication

ID	Skenario	Langkah uji	Expected result
----	----------	-------------	-----------------

AUTH-01	Register user baru	POST /api/v1/auth/register dengan email unik dan password valid.	201; access_token dan refresh_token diterima; audit AUTH_REGISTER tercatat.
AUTH-02	Register email duplikat	POST register dengan email yang sudah ada.	400; tidak membuat user baru; audit AUTH_REGISTER_DUPLICATE tercatat.
AUTH-03	Login valid	POST /api/v1/auth/login dengan kredensial benar.	200; token diterima; audit AUTH_LOGIN_SUCCESS tercatat.
AUTH-04	Login salah	POST login dengan password salah.	401; token tidak diterbitkan; audit AUTH_LOGIN_FAILURE tercatat.
AUTH-05	Refresh token valid	POST /api/v1/auth/refresh dengan refresh_token valid.	200; token baru diterbitkan; audit AUTH_TOKEN_REFRESH tercatat.
AUTH-06	Access endpoint protected tanpa token	GET /api/v1/auth/me tanpa Authorization header.	401 Unauthorized.
AUTH-07	Gunakan refresh token sebagai access token	GET /api/v1/auth/me memakai refresh_token.	401; refresh token ditolak sebagai access token.

5. Matriks Skenario Authorization

ID	Skenario	Langkah uji	Expected result
AUTHZ-01	Student submit lamaran	Student POST /api/v1/applications/ untuk opportunity aktif.	201; application dibuat untuk current_user.
AUTHZ-02	Student akses endpoint HR	Student PATCH /api/v1/applications/{id}/status.	403 Forbidden.
AUTHZ-03	HR lihat pelamar company sendiri	HR A GET /api/v1/applications/opportunity/{opportunityA_id}.	200; daftar pelamar company A tampil.
AUTHZ-04	HR lihat pelamar company lain	HR B GET opportunity milik company A.	403 Forbidden atau error ownership setara.
AUTHZ-05	HR update opportunity sendiri	HR A PUT /api/v1/opportunities/{opportunityA_id}.	200; data berubah dan tetap company A.
AUTHZ-06	HR update opportunity company lain	HR B PUT opportunity company A.	403 Forbidden.
AUTHZ-07	Admin akses endpoint admin	Admin GET /api/v1/admin/users.	200; daftar user tampil tanpa hashed_password.
AUTHZ-08	Non-admin akses endpoint admin	Student/HR GET /api/v1/admin/users.	403 Forbidden.
AUTHZ-09	Student akses resume milik sendiri	Student GET/PUT /api/v1/resumes/{resume_id} miliknya.	200; hanya data milik student tersebut.
AUTHZ-10	Student akses resume user lain	Student menggunakan resume_id milik user lain.	404/403; data tidak terekspos.

6. Matriks Skenario Accounting

ID	Event	Langkah uji	Expected audit evidence
----	-------	-------------	-------------------------

ACC-01	Login success/failure	Jalankan AUTH-03 dan AUTH-04.	Log memuat action, userEmail, resource auth, success true/false, timestamp.
ACC-02	Application submit	Student submit lamaran.	Log APPLICATION_SUBMIT atau event setara memuat actor student dan application/opportunity id.
ACC-03	Status update	HR update status lamaran.	Log APPLICATION_STATUS_UPDATE memuat HR actor, application id, status baru, success true.
ACC-04	Admin action	Admin toggle active/delete user pada data uji.	Log admin action memuat actor admin dan target resource.
ACC-05	Audit service unavailable	Matikan audit-log service lalu jalankan login valid.	API tetap merespons; backend tidak crash; kegagalan logging tidak mengekspos error ke user.

7. Skenario Enkripsi dan Proteksi Data Sensitif

ID	Objek uji	Langkah uji	Expected result
DATA-01	Password	Inspect response login/register dan query database uji.	Response tidak memuat hashed_password; database menyimpan bcrypt hash, bukan plaintext.
DATA-02	Profil student	HR yang tidak terkait mencoba membaca data student tanpa relasi lamaran.	Data pribadi tidak terekspos.
DATA-03	CV/resume	Student mencoba akses CV/resume milik user lain.	Ditolak oleh ownership check atau protected file access.
DATA-04	Audit payload	Periksa JSON audit log.	Tidak ada password, token, private key, atau isi CV penuh di log.
DATA-05	Secret management	Cari secret di repository dan dokumen.	Tidak ada SECRET_KEY asli, database password, atau private key yang dikomit.

8. Skenario Digital Signature

ID	Skenario	Langkah uji	Expected result
SIG-01	Sign status update	HR mengubah status lamaran pada workflow yang ditandatangani.	Canonical payload dibuat dan signature tersimpan bersama audit evidence.
SIG-02	Verify valid signature	Verifikasi payload dan signature tanpa perubahan data.	Verifikasi berhasil.

SIG-03	Detect tampered payload	Ubah salah satu field payload audit/status lalu verifikasi ulang.	Verifikasi gagal dan event kegagalan dicatat.
SIG-04	Private key exposure check	Cari private key di source code dan log.	Private key tidak muncul di repository, response, atau audit log.

9. Acceptance Criteria

Area	Kriteria lulus
Authentication	Semua skenario AUTH-01 sampai AUTH-07 menghasilkan status code dan audit event sesuai expected result.
Authorization	Tidak ada role yang dapat mengakses endpoint atau resource di luar role/ownership-nya.
Accounting	Audit log mencatat aktivitas penting dan tidak membocorkan secret atau data sensitif.
Data protection	Password hash, data profil, CV/resume, cover letter, dan history lamaran memiliki kontrol akses yang terbukti.
Digital signature	Payload aksi penting dapat ditandatangani, diverifikasi, dan gagal jika dimodifikasi.

10. Template Pencatatan Hasil

Tanggal	Tester	ID test	Result	Evidence/link log	Catatan
			Pass/Fail		
			Pass/Fail		
			Pass/Fail		
			Pass/Fail		